Studio Nx

Backend(FastAPI/Python) 43 — GET /api/v1/profile-images/{name}

2026-10-12

Backend(FastAPI/Python) 43 — `GET /api/v1/profile-images/{name}`

항목	내용
파일	`studionx/backend/app/api/v1/users.py`의 `images_router`, `read_profile_image()` / `app/api/v1/router.py` (한 줄)
작업	P1-08 회원 정보: 프로필 사진 파일 보내기 (PRD 01 FR-106)
작성	Claude (AI), 2026-10-07, 사용자 검토
이전 · 다음	42 `POST · DELETE /users/me/profile-image` · 44 `check current password()` (P1-09)

1. 하는 일

`<img src="/api/v1/profile-images/3f9c….jpg">`가 부르는 주소입니다. 사진 **파일 자체**를 보내며, 로그인은 필요하지 않습니다.

요청	응답
올린 사진의 주소 (토큰 없이)	200과 그림 바이트입니다. 헤더는 `Content-Type: image/jpeg`(png, webp도 각각 맞게), `X-Content-Type-Options: nosniff`, `Cache-Control: public, max-age=86400`입니다
없는 이름, 모양이 맞지 않는 이름	404 `NOT_FOUND` "Image not found."
지운 사진, 탈퇴한 회원의 사진	똑같이 404입니다
`..%2F..%2F.env`	404입니다. `/`로 풀려서 이 주소와 맞지도 않습니다 (앱 공통 404)
템플릿의 `/api/v1/users/85/profile-image`	404입니다. **없는 주소**입니다

2. 언제 쓰나

쓰는 곳	
화면의 `<img src>`	userInfo.html과 myPage.html의 프로필 사진(P1-10, P1-17), 협업 멤버 사진(Phase 6)
주소를 얻는 곳	36번 응답의 `profile_image_url`입니다 (35번이 만듭니다). 화면은 받은 주소를 그대로 넣기만 합니다

사용자 결정 반영 (35 §2)

템플릿의 주소는 `GET /users/{user_id}/profile-image`였습니다. **회원 번호로 여는 공개 주소는 만들지 않는다**(탈퇴 추적 방지 ③)는 결정에 따라 `/profile-images/{무작위 이름}`으로 바꿨습니다. 이 주소는 `/users` 아래가 아니어서 라우터를 하나 더 두었습니다.

바꾼 곳	내용
`users.py`	`images_router = APIRouter()`와 그 위에 놓인 라우터 함수
`router.py`	`api_router.include_router(users.images_router, prefix="/profile-images", tags=["users"])`

바꾼 곳	내용
`tests/test_user_routes.py`	연결 확인 시험을 새 주소로 바꾸고, 옛 주소는 **없다**는 것을 확인합니다

3. 코드

import (파일 맨 위: 41번과 같고, 새로 추가한 것은 없습니다). 이 함수는 **`FileResponse`**와 40번 `profile_image_file`을 사용합니다.

라우터와 상수 (이번에 추가)

```
# 사진 파일 — /api/v1/profile-images/{name} (회원 번호가 아니라 무작위 파일 이름, 2026-10-07)
# /users 아래가 아니라서 라우터를 따로 둠 → router.py 에서 prefix="/profile-images" 로 붙임
images_router = APIRouter()

# 확장자 → 응답 종류 (PHOTO_TYPES 를 뒤집음: ".jpg" → "image/jpeg")
PHOTO_MEDIA_TYPES = {ext: media for media, ext in user_service.PHOTO_TYPES.items()}
```

함수

```
@images_router.get(
    "/{name}",
    response_class=FileResponse,
    responses={404: {"model": ErrorResponse}},
)
def read_profile_image(name: str, db: Db) -> FileResponse:
    path = user_service.profile_image_file(db, name)
    return FileResponse(
        path,
        media_type=PHOTO_MEDIA_TYPES[path.suffix],
        headers={"Cache-Control": "public, max-age=86400", "X-Content-Type-Options": "nosniff"},
    )
```

문법 풀이

식	뜻
`{ext: media for media, ext in ….items()}`	**사전을 만드는 식**입니다. `PHOTO_TYPES`(`"image/jpeg": ".jpg"`)의 키와 값을 뒤집은 사전을 만듭니다
`"/{name}"`, `name: str`	주소의 마지막 부분이 `name` 매개변수로 들어옵니다
`FileResponse(path, …)`	파일을 조금씩 읽어서 보냅니다 (통째로 메모리에 올리지 않습니다)
`path.suffix`	확장자 `".jpg"` 입니다
`response_class=FileResponse`	문서(`/docs`)에 "파일 응답"으로 표시합니다

4. 흐름

1. 40번으로 파일을 찾습니다. 보여 줄 수 없는 경우라면 40번에서 404로 끝납니다.
2. 확장자로 파일 종류를 정하고, 캐시 헤더와 `nosniff` 헤더를 붙여서 파일을 보냅니다.

5. 왜 이렇게

선택	이유
로그인 확인을 하지 않음	`<img>`는 `Authorization` 헤더를 붙일 수 없습니다. 대신 주소가 무작위 32자라서 이름을 모르면 열 수 없습니다 (2^{128}가지)
종류를 **확장자로** 직접 정함	38번이 내용을 보고 확장자를 붙였으므로, 확장자가 곧 실제 종류입니다. 운영체제의 종류 표에 기대지 않습니다 (Windows는 `.webp`를 모를 수 있습니다)
`X-Content-Type-Options: nosniff`	브라우저가 내용을 보고 "사실은 HTML이네" 하고 다르게 해석하지 않게 합니다. 38번의 내용 검사와 함께 이중 잠금이 됩니다
캐시는 1일 (`max-age=86400`, 템플릿 제안)	같은 사진을 매번 다시 받지 않습니다. 사진을 바꾸면 **이름이 바뀌므로** 새로 받습니다. 더 길게(1년) 할 수도 있지만, 지운 사진이나 탈퇴한 회원의 사진이 다른 사람의 브라우저에 오래 남지 않도록 하루로 정했습니다
`public`	사진은 이름만 알면 누구나 볼 수 있는 자료이므로, 공유 캐시(CDN)에 두어도 결과가 같습니다
라우터를 `users.py` 안에 둠	회원 사진은 회원 정보의 일부입니다. 파일을 새로 만들면 템플릿 머리말과 안내가 여러 곳으로 갈라집니다

6. 시험 (`tests/test_user_routes.py`에 8개를 추가해서 모두 26개, 실제 앱과 MySQL, 임시 폴더로 실행)

시험	확인한 것
jpg, png, webp를 올린 뒤 응답 주소로 열기 (토큰 없이)	200이고, 바이트가 같으며, `Content-Type`이 각각 맞고, `nosniff`와 캐시 헤더가 있습니다
없는 이름, `..%2F..%2F.env`, 모양이 맞지 않는 이름	404 `NOT_FOUND`
지운 사진, 탈퇴한 회원의 사진	404
옛 주소 `/users/{번호}/profile-image`	열리지 않습니다
연결 확인 (DB 없이)	`/api/v1/profile-images/{name}`은 있고, 옛 주소는 없습니다

처음에는 1개가 실패했습니다. `%2F`가 `/`로 풀리면서 사진 주소와 맞지 않아 이 함수까지 오지 않고, 앱 공통 404("Not found.")가 났기 때문입니다. 안전한 결과이므로, 그 경우는 상태와 코드만 확인하도록 시험을 고쳤습니다. 전체 시험 314개가 통과했고, `ruff` 검사도 통과했습니다. 실제 `storage/` 폴더는 비어 있습니다.